

Industrial Security (Master)

Exercise Sheet – Section 04 Offensive ICS in Authorised Labs

Exercise 4.1 – Rules of Engagement

Draft a Rules of Engagement (ROE) document for a 1-week ICS penetration test of a fictional water utility. Include:

- Scope (what is in / out), with named devices and IP ranges.
- Timing (windows, holidays excluded, kill-switch).
- Approval chain (operations manager + CISO + safety engineer).
- Communications (start-of-day notice, daily status, end-of-day report).
- Forbidden actions (no DoS on safety systems, no writes to production PLCs).

Exercise 4.2 – Recon Plan

For the same utility, write a 1-page *passive-first* recon plan:

1. What you can learn from the corporate website + LinkedIn.
2. What passive network monitoring would reveal in 24 hours.
3. Which active probes you would attempt first, and why.
4. How to detect when you have triggered an SOC alert.

Exercise 4.3 – Attack Path

Pick one of: Modbus write, S7comm CPU stop, GOOSE spoof, OPC UA anonymous abuse. Document:

1. Pre-conditions (network access, credentials, equipment knowledge).
2. Step-by-step execution against your lab.
3. Process impact – what would a real plant operator see?
4. Detection opportunities at each step.

Exercise 4.4 – Report Writing

Take any one finding from Exercise 4.3 and produce a 1-page finding write-up: title, executive summary (3 sentences), CVSS-E, evidence (PCAP excerpt or screenshot), reproduction (numbered), recommendation (this-quarter / this-year).

Caution

Use only your lab. Reuse of lab findings against a real environment without authorisation crosses the line from training to crime.